

AMENDMENT OF SOLICITATION/MODIFICATION OF CONTRACT		BPA NO.	1. CONTRACT ID CODE	PAGE 1	OF 6	PAGES
2. AMENDMENT/MODIFICATION NUMBER 0002		3. EFFECTIVE DATE 04-29-2026	4. REQUISITION/PURCHASE REQ. NUMBER		5. PROJECT NUMBER (if applicable) VA-26-00046145	
6. ISSUED BY CODE Department of Veterans Affairs Technology Acquisition Center 23 Christopher Way Eatontown NJ 07724		7. ADMINISTERED BY (If other than Item 6) CODE Department of Veterans Affairs Technology Acquisition Center 23 Christopher Way Eatontown NJ 07724				
8. NAME AND ADDRESS OF CONTRACTOR (Number, street, county, State and ZIP Code) To all Offerors/Bidders			(X)	9A. AMENDMENT OF SOLICITATION NUMBER 36C10B26Q0339		
			☒	9B. DATED (SEE ITEM 11)		
			☐	10A. MODIFICATION OF CONTRACT/ORDER NUMBER		
				10B. DATED (SEE ITEM 13)		
CODE		FACILITY CODE				
11. THIS ITEM ONLY APPLIES TO AMENDMENTS OF SOLICITATIONS						
☒ The above numbered solicitation is amended as set forth in Item 14. The hour and date specified for receipt of Offers ☐ is extended, ☒ is not extended. Offers must acknowledge receipt of this amendment prior to the hour and date specified in the solicitation or as amended, by one of the following methods: (a) By completing Items 8 and 15, and returning _____ copies of the amendment; (b) By acknowledging receipt of this amendment on each copy of the offer submitted; or (c) By separate letter or electronic communication which includes a reference to the solicitation and amendment numbers. FAILURE OF YOUR ACKNOWLEDGMENT TO BE RECEIVED AT THE PLACE DESIGNATED FOR THE RECEIPT OF OFFERS PRIOR TO THE HOUR AND DATE SPECIFIED MAY RESULT IN REJECTION OF YOUR OFFER. If by virtue of this amendment you desire to change an offer already submitted, such change may be made by letter or electronic communication, provided each letter or electronic communication makes reference to the solicitation and this amendment, and is received prior to the opening hour and date specified.						
12. ACCOUNTING AND APPROPRIATION DATA (If required)						
13. THIS ITEM APPLIES ONLY TO MODIFICATIONS OF CONTRACTS/ORDERS, IT MODIFIES THE CONTRACT/ORDER NO. AS DESCRIBED IN ITEM 14.						
CHECK ONE	A. THIS CHANGE ORDER IS ISSUED PURSUANT TO: (Specify authority) THE CHANGES SET FORTH IN ITEM 14 ARE MADE IN THE CONTRACT ORDER NO. IN ITEM 10A.					
☐						
☐	B. THE ABOVE NUMBERED CONTRACT/ORDER IS MODIFIED TO REFLECT THE ADMINISTRATIVE CHANGES (such as changes in paying office, appropriation date, etc.) SET FORTH IN ITEM 14, PURSUANT TO THE AUTHORITY OF FAR 43.103(b).					
☐	C. THIS SUPPLEMENTAL AGREEMENT IS ENTERED INTO PURSUANT TO AUTHORITY OF:					
☐	D. OTHER (Specify type of modification and authority)					
E. IMPORTANT: Contractor ☐ is not, ☐ is required to sign this document and return _____ copies to the issuing office.						
14. DESCRIPTION OF AMENDMENT/MODIFICATION (Organized by UCF section headings, including solicitation/contract subject matter where feasible.) See Continuation Pages						
Except as provided herein, all terms and conditions of the document referenced in Item 9A or 10A, as heretofore changed, remains unchanged and in full force and effect.						
15A. NAME AND TITLE OF SIGNER (Type or print)			16A. NAME AND TITLE OF CONTRACTING OFFICER (Type or print) Brett Schwerin Contracting Officer			
15B. CONTRACTOR/OFFEROR (Signature of person authorized to sign)		15C. DATE SIGNED	16B. UNITED STATES OF AMERICA (Signature of Contracting Officer)		16C. DATE SIGNED	

- A. The purpose of this amendment is to provide the Government's official responses to the questions submitted by interested vendors on April 19, 2026.

The questions and the Government's corresponding responses are set forth below.

Question 1: Patient Lay Summary Letters (PWS Section 5.2.8.B): Section 5.2.8.B requires the system to "allow for some nationally standardized portions of the Results letters that cannot be changed locally, while still allowing some aspects of the results letter to be customized by the facility." Patient Hub currently supports results letter customization by facility (including by state), but does not enforce nationally standardized, non-editable letter components.

Can VA clarify what specific portions of the results letters are intended to be nationally standardized, and whether facility-level customization (which would allow facilities to adopt a common standard voluntarily) meets this requirement?

Response: The VA wants to nationally standardize and require the lay summary letters utilize FDA breast density statements. The goal is to standardize as much as possible.

Question 2: Disaster Recovery and Backup Responsibilities (PWS Section 5.3, Technical Functionality, Item 2): Section 5.3 requires the Contractor to provide a comprehensive disaster recovery plan, including a process for performing automated system backups, a process for restoring system backups, and a summary of third-party enterprise backup solutions/agents that the MTRS system supports. Because Patient Hub will be hosted on VA infrastructure, backup and restore operations will be performed by VA IT using VA enterprise tools.

Can the VA confirm that (a) responsibility for executing, scheduling, and monitoring system backups and restorations rests with VA IT, and (b) a vendor's obligation under Section 5.3(2) is limited to documenting Patient Hub's compatibility with VA's enterprise backup solutions and providing technical guidance to support VA's backup and recovery processes?

Response: VA confirms that it is a VA responsibility to execute system back-ups and restorations. The expectation is that the contractor would provide a comprehensive plan for VA to execute based on the technical compatibility and capability of the MTRS system backup features and processes. The contractor shall also provide technical guidance as required for the backup and recovery process.

Question 3: Patching Responsibilities (PWS Section 5.12.F and Addendum B, Section B6.n): Section 5.12.F requires the Contractor to provide technical expertise regarding system patching and updates, including operating system (OS) patches, application updates, database updates, and system vulnerabilities. Section B6.n further requires the Contractor to apply security fixes within specified timeframes

when the Contractor is responsible for operations or maintenance of the systems. Because Patient Hub will be hosted on VA infrastructure, OS patching is performed by VA IT.

Can the VA confirm that (a) responsibility for OS-level patching rests with VA IT, (b) a vendor's patching obligations under Sections 5.12.F and B6.n are limited to application-layer and database updates for the Patient Hub software, and (c) A vendor's role with respect to OS patches is limited to providing technical guidance, compatibility validation, and support to VA IT as needed?

Response: VA confirms that OS level patching rests with VA assuming the MTRS solution can receive all OS patches from the VA's medical device update server (MDUS). The contractor's role with respect to OS patches is indeed limited to providing technical guidance, compatibility validation, and support to VA HTM/IT as needed for known OS related updates that have known issues with the MTRS software. The contractor will play a more direct/prominent role in the application layer and database updates for the MTRS software.

Question 4: Security Incident Reporting Timeline (PWS Addendum B, Section B5.a and Addendum A, Section A1.0): Section B5.a requires reporting of suspected security/privacy incidents to the VA Enterprise Service Desk within one hour, and Section A1.0 similarly requires notice to the COR/CO within one hour of disclosure or successful exploits of vulnerabilities. Industry practice, and a vendor's standard incident response procedures, provide for customer notification within 24 hours, which allows time for initial triage and confirmation of whether an event constitutes a reportable incident.

Can the VA (a) extend the notification window to 24 hours for suspected incidents, with the one-hour window reserved for confirmed incidents materially impacting VA data, and (b) clarify whether the one-hour clock begins upon suspicion or upon confirmation?

Response: This language is standard from the TAC template. We recommend it not be changed. The one-hour clock begins upon suspicion.

Question 5: Definition of "Suspected Security / Privacy Incident" (PWS Addendum B, Section B5.a): Section B5.a requires immediate (within one hour) reporting of "suspected security / privacy incidents" but does not define the term.

Can the VA provide a definition, including examples of events that do and do not trigger the reporting obligation (e.g., unsuccessful login attempts, routine vulnerability scan findings, suspected phishing attempts without confirmed compromise)?

Response: The term “incident” is defined as: An occurrence that actually or imminently jeopardizes, without lawful authority, the confidentiality, integrity, or availability of information or an information system; or constitutes a violation or imminent threat of violation of law, security policies, security procedures, or acceptable use policies.

Regarding examples, each system with an Authority to Operate is unique, reporting criteria vary accordingly. An event that constitutes an incident in one system may not meet the criteria in another. To ensure precision and consistency, incidents are evaluated in alignment with the specific requirements established for each individual system.

Question 6: System Isolation Requirement (PWS Addendum B, Section B7.i): Section B7.i requires that, upon disclosure of a vulnerability that could compromise the confidentiality, integrity, or availability of the information systems, "the system or effected component(s) need(s) to be isolated from the network" within one hour.

Given that Patient Hub is hosted on VA networks and patching is handled by VA IT, can the VA confirm (a) that the isolation obligation applies to VA IT, not the Contractor, and (b) that a vendor’s obligation is limited to providing technical support and timely notice to enable VA to perform isolation?

Response: VA confirms that the isolation obligation would fall on the VA since this will be a VA hosted system, however technical support and timely notice is required from the vendor to enable VA to perform the isolation. Isolation obligations from the vendor side may include severing connections to the VA network if suspicious activity is detected on the Contractor’s network.

Question 7: Annual Self-Assessment and Audit Rights (PWS Addendum B, Sections B7.g, B8.a, B8.b, and B8.c): Sections B7.g and B8 establish a broad set of audit rights, including annual Contractor self-assessments, scheduled and unscheduled VA/3PAO/OIG audits, penetration tests, interviews, document review, and disclosure of Contractor cybersecurity framework documentation (ISO, NIST CSF, etc.).

Can the VA confirm (a) that A vendor may satisfy the self-assessment and documentation obligations by providing its current SOC 2 Type II report and ISO 27001 certification (or equivalents) in lieu of new VA-specific assessments, and (b) that penetration testing will be coordinated in advance with reasonable notice (at least 30 business days, consistent with B8.b) and will not disrupt a vendor’s production environment or other customers?

Response:

- a. Vendor self-assessment documentation will be reviewed. If it is not sufficient, the VA may require the VA specific assessments be performed with reasonable lead time.
- b. VHA HTM concurs the penetration testing would be coordinated in advance in a manner that will not intentionally impact VA operations/clinical care.

Question 8: Cybersecurity Vulnerability Notification Scope (PWS Addendum A, Section A1.0): Section A1.0 requires A vendor to notify the COR/CO within one hour "of disclosure or successful exploits of any vulnerability which can compromise the confidentiality, integrity, or availability of the information systems." A vendor's standard practice is to notify customers when a vulnerability cannot be mitigated within the agreed timeframe, rather than upon every patch application or routine vulnerability discovery.

Can the VA confirm the notification obligation is limited to (a) confirmed exploits, or (b) vulnerabilities that A vendor cannot mitigate within the applicable remediation window in Section B12?

Response: The one-hour clock begins upon suspicion.

Question 9: Data Destruction on Contract Termination (PWS Addendum B, Sections B2.n, B2.o, and B7.c): Sections B2.n, B2.o, and B7.c require A vendor to provide a plan for destruction of all VA data in its possession prior to termination or completion of the contract, with self-certification within 30 business days of termination.

Given that Patient Hub is hosted on VA networks, can the VA confirm that (a) data residing on VA-owned infrastructure is the VA's responsibility to destroy, and (b) A vendor's destruction obligation is limited to any VA data transferred to or processed within A vendor-controlled environments (e.g., support ticket attachments)?

Response: VA confirms that the vendor's role to this requirement would be focused on data transferred to, or processed, within the vendor's environment for technical support as the system would be hosted in the VA environment.

Question 10: Personnel Roster and Background Investigation POC (PWS Section 6.2.2.b): Section 6.2.2.b requires A vendor to provide a roster of Contractor and Subcontractor employees within 3 business days after award to begin background investigations, including full Social Security Numbers. In prior VA contracts, A vendor has requested but not received a designated VA POC for coordinating fingerprinting and investigation submissions.

Can the VA (a) identify the designated COR or Personnel Security Adjudication Center (PSAC) POC prior to award to enable A vendor to meet the 3-business-day

requirement, and (b) confirm that the investigation level requirement is Tier 1 / Low Risk for all tasks in Section 5, consistent with the matrix in Section 6.2.1?

Response: Tier 1 is appropriate based on advance consultations done with VA personnel vetting and security team. The POC will be identified to meet the timeline.

Question 11: Patch Notification Cadence (PWS Addendum B, Section B6.n): Section B6.n requires written notice to the VA COR/CO within 10 business days each time a third-party patch (e.g., Microsoft OS, Adobe) is validated.

Given that Patient Hub is hosted on VA networks and OS patching is handled by VA IT, can the VA confirm that (a) this requirement applies only to application-layer and database patches within a vendor's responsibility, and (b) routine validated patches may be reported in the Monthly Progress Report rather than as separate notices?

Response: If the Contractor indicates that the VA can automatically apply all patches, the contractor must notify the VA within 10 days if an automatic patch is not compatible with their system. If the Contractor indicates that the contractor's system cannot handle OS patches automatically being applied (requires validation), then the contractor needs to inform the VA within 10 days of new patch releases being validated.

B. The response date and time of May 4, 2026, 1:00pm ET remain unchanged.